

INS Mod 4

TCP/IP Vulnerabilities and Protocol Flaws:

- **Weak Authentication and Validation:** Many protocols in the TCP/IP suite lack built-in mechanisms for verifying the identity of communicating parties. This makes it easier for attackers to impersonate legitimate devices.
- **Predictable Sequence Numbers:** TCP relies on sequence numbers for data integrity and to ensure packets are reassembled correctly. However, predictable sequence numbers in some implementations can allow attackers to hijack a session or inject malicious data.
- **Absence of Encryption:** The core TCP/IP protocols (like IP, TCP, and UDP) do not include encryption, making transmitted data susceptible to interception and tampering if not protected by higher-layer protocols like TLS.

Reconnaissance of Network:

- **Network Mapping:** Attackers use tools like Nmap to create a map of the target's network. This step identifies all devices, their IP addresses, and their roles within the network.
- **Port Scanning:** Once attackers know which devices are live, they scan ports to find open ones, identifying services and applications that are accessible on the network and looking for specific vulnerabilities.
- **Service Detection:** Attackers attempt to identify specific services and versions (like Apache or Microsoft IIS) to determine if known vulnerabilities can be exploited. This information is crucial in planning the attack.

Social Engineering:

- **Phishing:** One of the most common techniques, where attackers send emails pretending to be trusted entities (like banks or employers) to trick users into revealing sensitive information or clicking malicious links.
- **Pretexting:** Attackers fabricate a scenario to gain trust, often by impersonating authority figures (like IT support) to request information directly from users.
- **Baiting and Quid Pro Quo:** In baiting, attackers offer something enticing, like free software, which is actually malware. Quid pro quo involves offering a service (like "fixing" a problem) to get the target to reveal confidential information.

Packet Sniffing and Attacks:

- **Packet Sniffing:** Tools like Wireshark are used to capture network traffic, allowing attackers to see data packets, including passwords, session tokens, and other sensitive data, if transmitted in plaintext.
- **Session Hijacking:** By capturing session cookies or tokens, an attacker can gain control over an active session. This is particularly dangerous for web applications without proper security controls (e.g., those lacking HTTPS).

- **ARP Spoofing:** Attackers send forged ARP requests, which reroute network traffic through their system. This allows them to capture, modify, or block communications. ARP spoofing is often a precursor to other attacks like MITM (Man-in-the-Middle).

IP Spoofing:

- **False IP Source Address:** Attackers alter the packet header to make it look like the packet originated from a trusted IP address, allowing them to bypass IP-based access controls.
- **Anonymous Attacks:** By hiding the true source, attackers can avoid detection and attribution, making it harder for defenders to trace the source of the attack.
- **Component in DoS/DDoS Attacks:** IP spoofing is often used in flooding attacks to conceal the attacker's identity and prevent traffic filtering based on IP addresses.

DoS (Denial of Service) and DDoS (Distributed Denial of Service):

- **DoS Attack:** A single attacker attempts to exhaust resources on the target by sending a flood of requests, causing high CPU or memory usage that slows down or disables the service. Methods include SYN floods, where incomplete connection requests overload the server's resources.
- **DDoS Attack:** A large number of distributed devices (often a botnet) generate high volumes of traffic or requests toward the target. DDoS attacks are harder to mitigate due to the sheer scale and distribution of the attack sources.
- **Application-Layer Attacks:** These target specific application-level functions, such as login pages or search functions, exhausting resources in a way that is less obvious and more challenging to detect than typical network-layer attacks.

Firewalls: A firewall is a network security device or software that monitors and controls incoming and outgoing network traffic based on predetermined security rules. Its primary goal is to act as a barrier between a trusted internal network and untrusted external networks, such as the internet. Types of Firewalls:

- **Packet-Filtering Firewalls:** These analyze individual packets and filter them based on IP addresses, protocols, port numbers, and other predefined rules. They are relatively fast but lack the ability to inspect the payload (content) of each packet.
- **Stateful Inspection Firewalls:** These keep track of the state of active connections and make decisions based on the context of traffic rather than just the packet itself. They are more secure than packet-filtering firewalls but are also more resource-intensive.
- **Application-Layer Firewalls (Proxy Firewalls):** Operating at the application layer, these firewalls can inspect and filter traffic based on application-specific commands (like HTTP or FTP) and content, allowing fine-grained control.
- **Next-Generation Firewalls (NGFWs):** NGFWs combine traditional firewall capabilities with additional features like deep packet inspection, intrusion prevention, and application awareness, making them a popular choice for modern, complex network environments.

Firewall Deployment Architectures:

- Network Firewalls: Positioned at the network perimeter, they secure the boundary between an internal network and external networks.
- Host-Based Firewalls: Installed on individual devices (servers or endpoints), host-based firewalls control traffic to and from a single host. They provide an additional layer of security inside the network.

Firewall Policies and Rules:

- Firewalls operate based on rules configured by network administrators, specifying what types of traffic are allowed or denied. These rules are essential to defining how the firewall will behave and are tailored to organizational security requirements.
- Firewalls often implement the principle of “default deny,” which blocks all traffic except what is explicitly allowed, minimizing the risk of unauthorized access.
- Limitations of Firewalls:
- Firewalls cannot prevent internal threats or detect compromised systems that initiate outbound malicious traffic.
- They lack deep insight into sophisticated attacks such as insider threats, encrypted malicious traffic, or application-layer vulnerabilities.

Intrusion Detection Systems (IDS): An IDS is a monitoring system that detects suspicious activities and potential intrusions within a network or on a specific host. Unlike firewalls that block traffic based on predefined rules, an IDS primarily monitors, analyzes, and alerts administrators of potential security incidents.

Types of IDS:

- Network-Based IDS (NIDS): Placed at strategic points within a network (like behind firewalls), a NIDS monitors network traffic to and from all devices, searching for known attack signatures, anomalies, or policy violations.
- Host-Based IDS (HIDS): Installed on individual devices, a HIDS monitors activities like file modifications, unauthorized logins, and changes to configurations. It is effective for detecting suspicious activity on critical servers.

Detection Methods:

- Signature-Based Detection: The IDS uses a database of known attack patterns, or “signatures,” to identify potential threats. While effective for known threats, this method struggles with novel or polymorphic attacks that do not match existing signatures.
- Anomaly-Based Detection: This approach establishes a baseline of normal network behavior and flags deviations from the norm as potentially malicious. It can detect zero-day attacks but may produce a higher number of false positives if not tuned correctly.
- Hybrid Detection: Some IDS systems combine both signature and anomaly-based detection methods to improve accuracy and reduce false positives.

IDS Alerting and Response:

- When an IDS detects a potential threat, it generates alerts that can be forwarded to a Security Operations Center (SOC) for analysis. The IDS does not inherently take any direct action to block the attack but relies on the security team to respond.
- Modern IDS solutions can be integrated with automation and response platforms to enable quick reactions to critical alerts.

Challenges and Limitations of IDS:

- False Positives: Anomaly-based IDSs can generate frequent false positives, overwhelming security personnel and causing “alert fatigue.”
- Resource Intensive: IDS solutions, especially those analyzing large amounts of traffic in real time, require significant resources and can impact network performance.
- Evasion Techniques: Attackers may use techniques to evade detection, such as fragmenting packets or encrypting malicious payloads, which can make it harder for an IDS to identify threats accurately.

Honeypots: A honeypot is a decoy system or service designed to attract attackers and distract them from valuable assets on the network. Honeypots serve as traps, gathering information about attack methods and potentially delaying attackers while protecting sensitive data.

Types of Honeypots:

- Low-Interaction Honeypots: These simulate common network services or applications with minimal functionality. They are easier to deploy and manage but only capture basic information about attackers and are often detected quickly by skilled attackers.
- High-Interaction Honeypots: These provide a realistic environment that allows attackers to interact deeply with the system, giving security teams valuable insights into their methods. High-interaction honeypots are more resource-intensive and carry higher risk if attackers manage to escape the honeypot.
- Research vs. Production Honeypots: Research honeypots are used by security researchers to gather data on new attack trends and techniques, while production honeypots are deployed within corporate networks to detect and mitigate threats targeting specific systems or services.

Honeynets and Honeytokens:

- Honeynet: A network of honeypots that mimic the layout and services of an actual network. Honeynets provide a more comprehensive view of attacker behavior and can reveal coordinated attack methods.
- Honeytokens: Not physical devices, but rather decoy data or files, such as fake credentials or documents, planted within a network. When accessed, they trigger alerts, helping to detect insider threats or unauthorized access.

Advantages of Honeypots:

- **Early Threat Detection:** Honeypots can identify and monitor suspicious activity without affecting real systems. By luring attackers into a controlled environment, honeypots allow administrators to learn about potential vulnerabilities and strengthen defenses.
- **Insight into Attack Techniques:** Honeypots provide valuable intelligence on new attack vectors and methods, which can inform security measures and improve detection capabilities.
- **Reduction of False Positives:** Since honeypots do not serve any legitimate purpose, any interaction with them is likely to be suspicious, reducing the occurrence of false positives common in IDS and firewall alerts.

Risks and Limitations:

- **Risk of Attack Escalation:** In high-interaction honeypots, if attackers identify the honeypot and breach it, they may use it as a launching point for attacks on other systems.
- **Detection by Attackers:** Skilled attackers may identify honeypots through telltale signs, such as unusual response behaviors or network characteristics, and may avoid them, reducing their effectiveness.
- **Maintenance and Management:** Honeypots require regular updates, monitoring, and analysis, especially high-interaction honeypots that need to mimic a realistic environment to capture meaningful data.